

THREAT ADVISORY

VULNERABILITY REPORT

Citrix Addresses Auth bypass Flaws Affecting ADC and Gateway Products

Date of Publication

November 11, 2022

Admiralty Code

A1

TA Number

TA2022253

Summary

First Seen: November 8, 2022

Affected Product: Citrix Gateway and Citrix ADC

Impact: Results in unauthorized access and remote desktop takeover

CVEs

CVE	NAME	PATCH
CVE-2022-27510	Unauthorized access to Gateway user capabilities in Citrix	
CVE-2022-27513	Remote desktop takeover via phishing in Citrix	
CVE-2022-27516	User login brute force protection functionality bypass in Citrix	

Vulnerability Details

#1

Citrix has addressed bugs in Citrix ADC and Citrix Gateway. A remote intruder could exploit either of these flaws to obtain control of a susceptible system. To successfully exploit the vulnerability in Gateway appliances, it must be configured as a VPN (Gateway) and RDP proxy. Additionally, the adversary needs to have initial network access via an SSL-VPN gateway.

#2

CVE-2022-27510 is a critical-severity authentication bypass bug that exists and is attributed to an error in the authentication procedure. When exploited, the weakness enables a remote, unauthenticated attacker to evade the authentication mechanism and obtain unauthorized access to Gateway user privileges.

#3

The remote desktop takeover via phishing flaw exists due to poor verification of data authenticity within the RDP proxy, which is tracked under CVE-2022-27513. Finally, CVE-2022-27516 is a faulty implementation of the maximum login attempts that allows brute-force attacks.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-27510	Citrix Access Gateway: version before 12.1.65.21 and Citrix ADC: version before 12.1-55.289	cpe:2.3:a:citrix:citrix_access_gateway:*:*:*:*:*:*	CWE-288
CVE-2022-27513		*:*	CWE-345
CVE-2022-27516		cpe:2.3:o:citrix:application_delivery_controller_firmware:*:*:*:*:*:*	CWE-693

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Details' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0003</u> Persistence	<u>TA0006</u> Credential Access	<u>TA0008</u> Lateral Movement
<u>T1566</u> Phishing	<u>T1574</u> Hijack Execution Flow	<u>T1556</u> Modify Authentication Process	<u>T1110</u> Brute Force
<u>T1210</u> Exploitation of Remote Services			

Patch Link

<https://support.citrix.com/article/CTX463706/citrix-gateway-and-citrix-adc-security-bulletin-for-cve202227510-cve202227513-and-cve202227516>

References

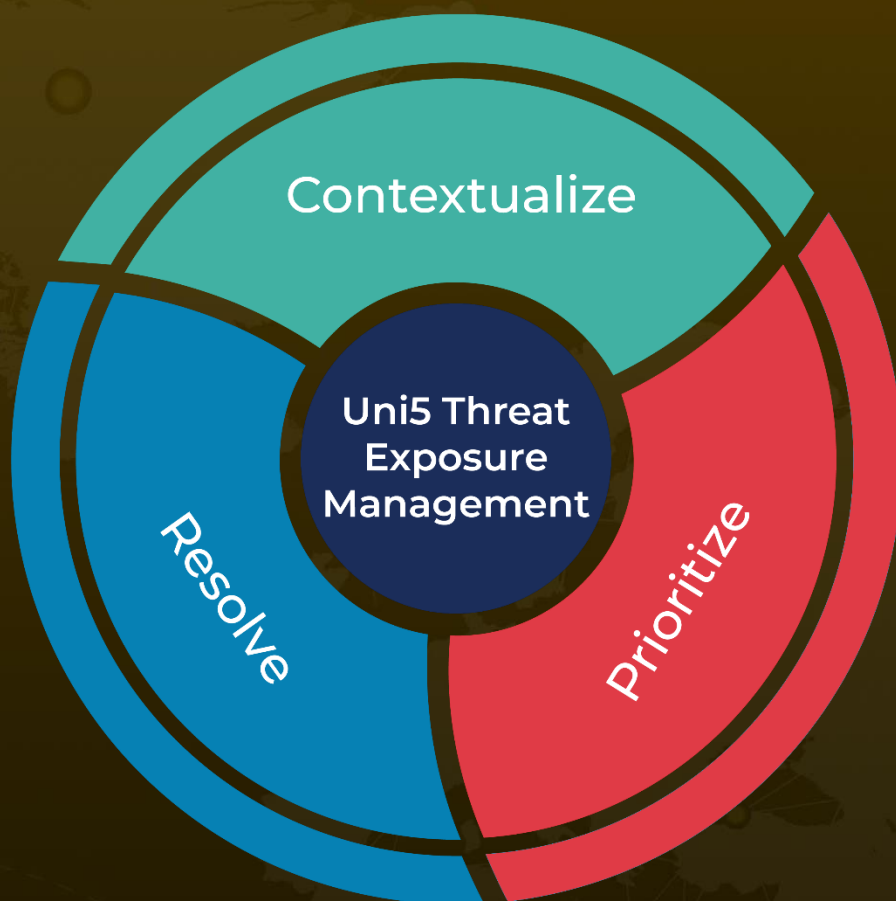
<https://www.bleepingcomputer.com/news/security/citrix-urges-admins-to-patch-critical-adc-gateway-auth-bypass/>

<https://thehackernews.com/2022/11/citrix-issues-patches-for-critical-flaw.html>

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 11, 2022 • 2:10 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com